WEB SECURITY ACADEMY · PORTSWIGGER

Username Enumeration via Response Timing

Resolución guiada paso a paso de un laboratorio de autenticación: enumeración de usuarios por canal lateral de tiempo y evasión del bloqueo anti fuerza bruta con Burp Intruder

Creado por

vareCruzz

Nivel: Practitioner · Categoría: Authentication · Herramienta: Burp Suite

Introducción al laboratorio

Este documento explica, de forma clara y detallada, la resolución del laboratorio de PortSwigger «Username enumeration via response timing» (Enumeración de nombres de usuario a través del tiempo de respuesta). Es un laboratorio de nivel Practitioner dentro de la categoría de vulnerabilidades de autenticación, un escalón más complejo que la enumeración por mensajes de error.

El objetivo declarado es el siguiente: la aplicación es vulnerable a enumeración de usuarios a través de sus tiempos de respuesta. Se dispone de credenciales propias (`wiener:peter`) y de dos listas de palabras candidatas (usuarios y contraseñas). Para resolver el laboratorio hay que:

- Enumerar un nombre de usuario válido a partir del tiempo de respuesta del servidor.
- Evadir la protección anti fuerza bruta basada en la IP de origen.
- Forzar la contraseña de ese usuario y acceder a su cuenta.

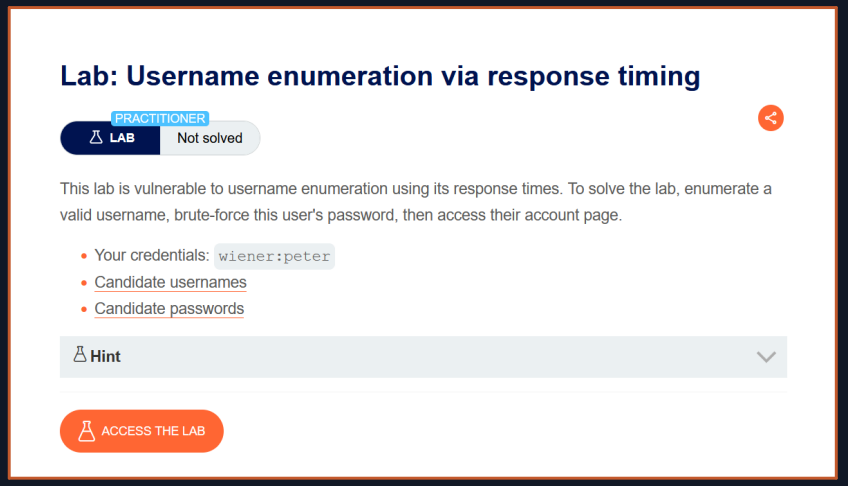


Figura 1. Descripción oficial del laboratorio en PortSwigger Web Security Academy.

Idea central de la vulnerabilidad: cuando el nombre de usuario existe, el servidor realiza una operación costosa (calcular el hash de la contraseña para compararla) antes de rechazar el login; cuando el usuario no existe, rechaza la petición de inmediato sin ese cálculo. Esa diferencia de tiempo, aunque sea de milisegundos, es un canal lateral que delata qué usuarios son reales sin necesidad de ningún mensaje de error distinto.

02 Resolución paso a paso

A continuación se detalla el proceso completo, apoyado en las capturas reales de la sesión, usando Burp Repeater para establecer una línea base y Burp Intruder, en modo Pitchfork, para automatizar tanto la rotación de IPs como el envío de los distintos candidatos.

1 Revisar el formulario de login con las credenciales propias

Lo primero es abrir la página de login e introducir las credenciales propias proporcionadas por el laboratorio: `wiener` / `peter`. Esto servirá como referencia para comparar después los tiempos de respuesta del servidor.

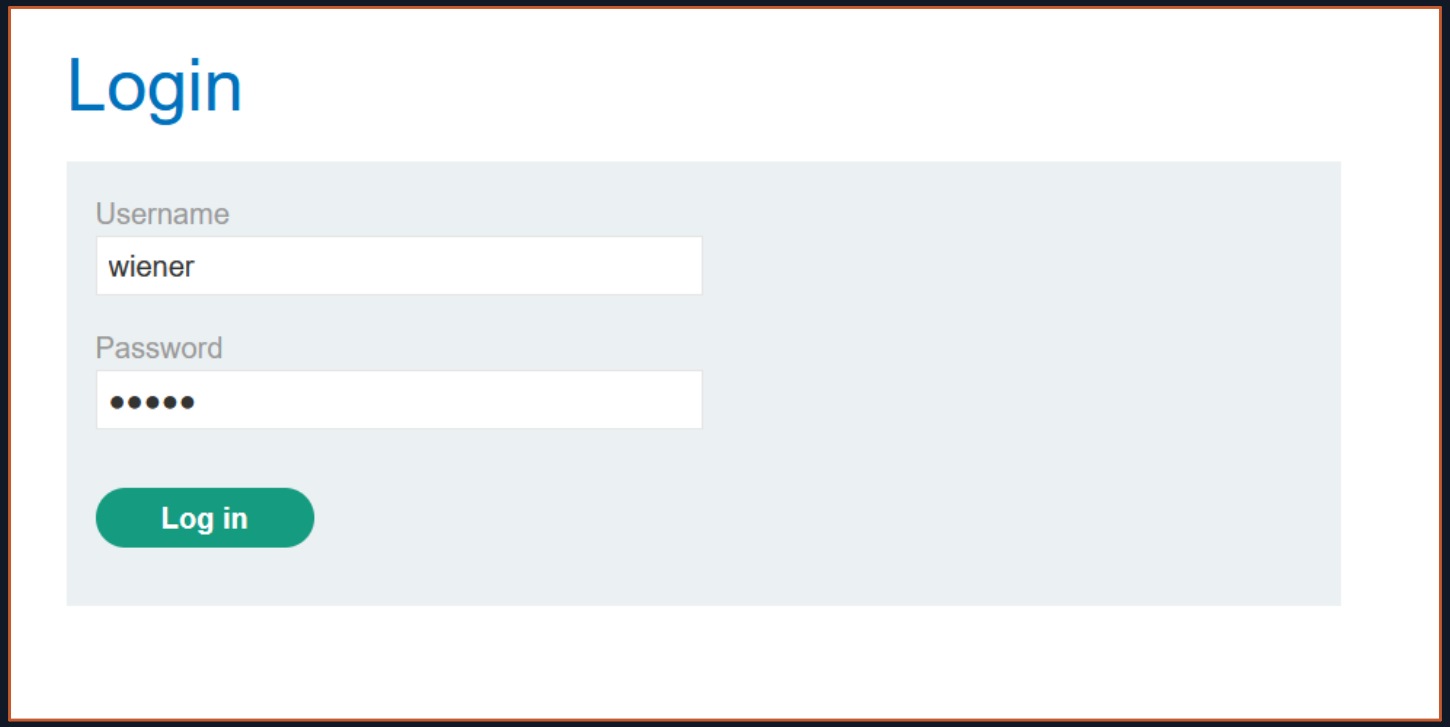


Figura 2. Formulario de login con las credenciales propias «wiener».

2 Establecer una línea base de tiempo con un login válido

Con Burp Repeater, se envía la petición `POST /login` con las credenciales correctas `wiener:peter`. La respuesta es un `302 Found` hacia `/my-account?id=wiener` en unos 203 ms: esta es la referencia de un login completo y válido.

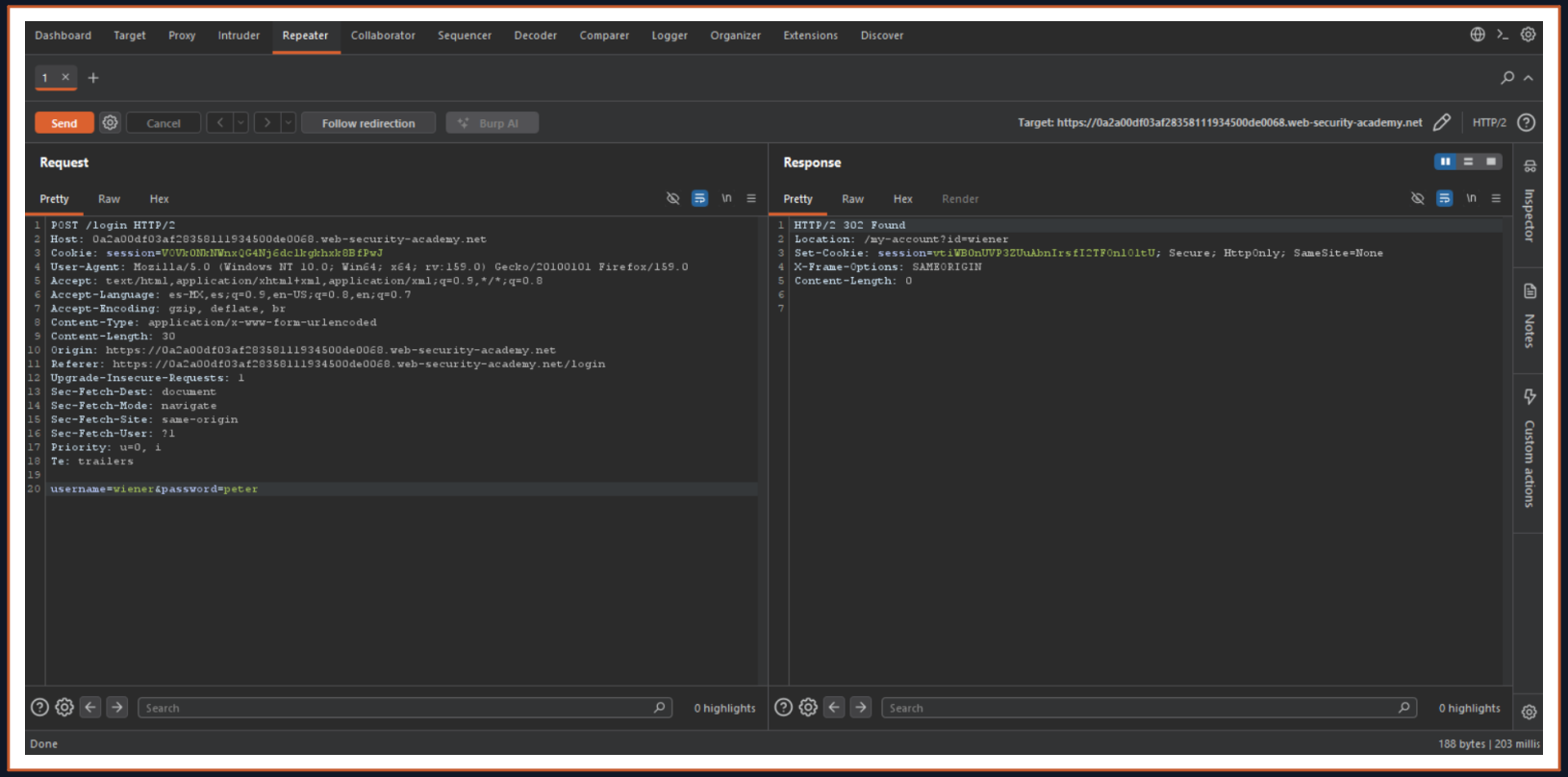


Figura 3. Login válido con wiener/peter → 302 Found en 203 ms.

3 Detectar la protección anti fuerza bruta basada en IP

Al repetir intentos fallidos (por ejemplo, `user:user`), la aplicación responde con «You have made too many incorrect login attempts. Please try again in 30 minute(s).». Esto confirma que existe un bloqueo temporal tras varios fallos, que impedirá automatizar un ataque de fuerza bruta directo sin antes evadirlo.

Problema a resolver: hay que encontrar la forma de que cada petición del ataque automatizado parezca venir de una IP distinta.

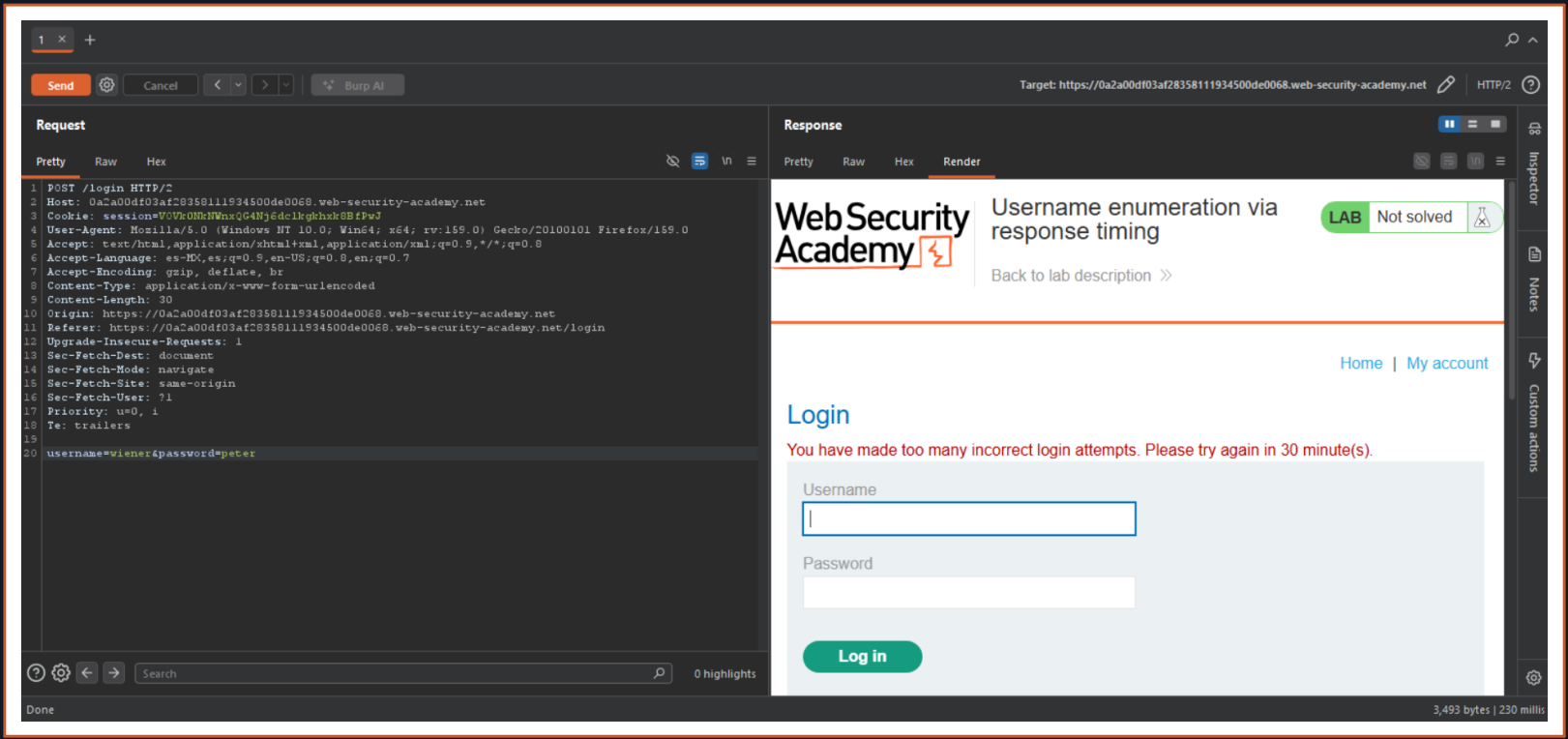


Figura 4. Mensaje de bloqueo tras demasiados intentos fallidos.

4 Configurar un ataque Pitchfork para rotar la IP de origen

En Burp Intruder se configura un ataque Pitchfork con dos posiciones de payload: la cabecera `X-Forwarded-For: 172.12.10.$0$` (un número del 1 al 101, para simular una IP de origen distinta en cada petición) y el campo `username=$user$`, dejando una contraseña larga e incorrecta fija. Así se evita el bloqueo por IP mientras se prueba cada nombre de usuario.

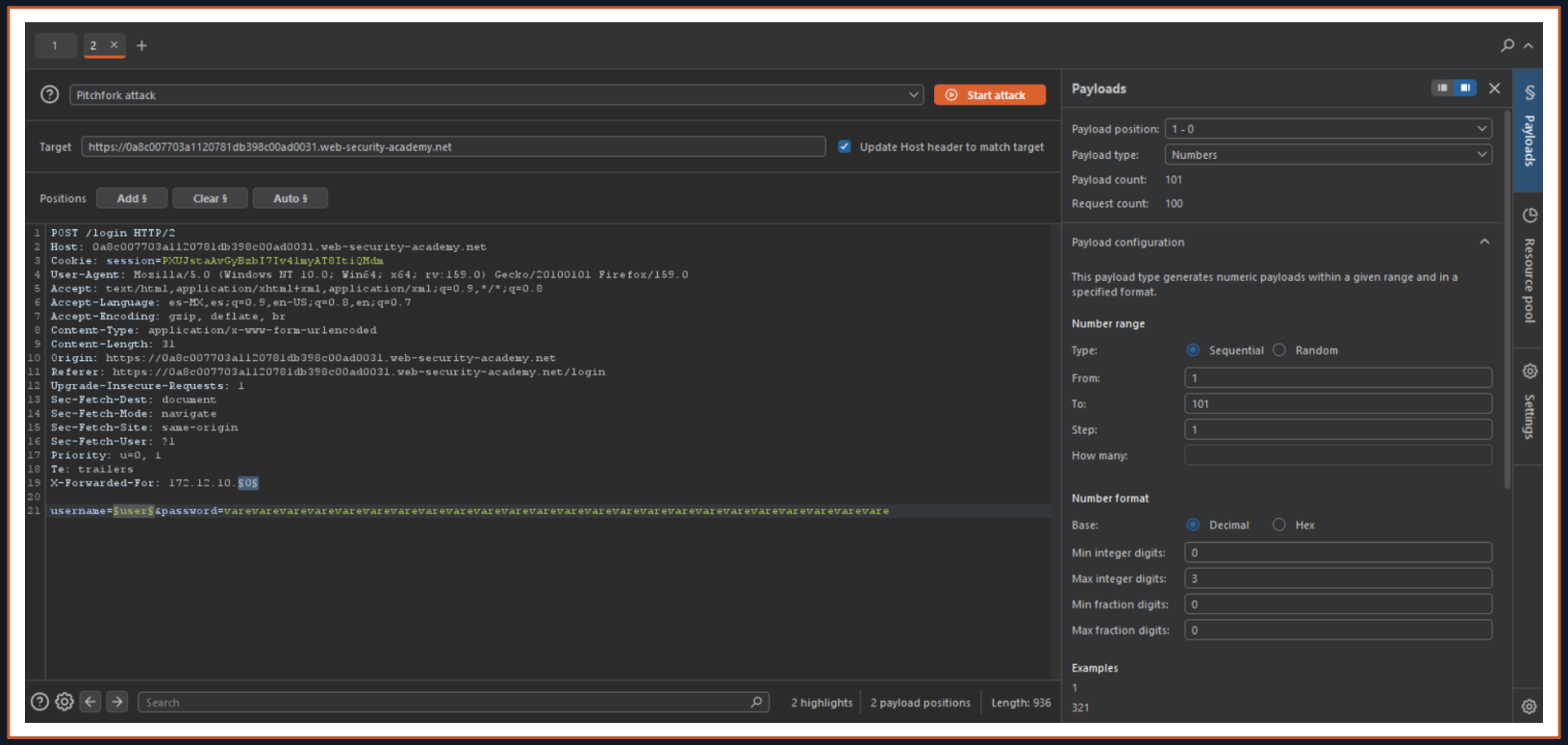


Figura 5. Ataque Pitchfork: IP falsificada vía X-Forwarded-For + posición en «username».

5 Cargar la lista de nombres de usuario candidatos

En la segunda posición de payload se carga la lista de candidate usernames del laboratorio (carlos, root, admin, test, guest, info, adm, mysql, user, y muchos más), con 101 candidatos en total, emparejados uno a uno con los 101 números de IP falsificada.

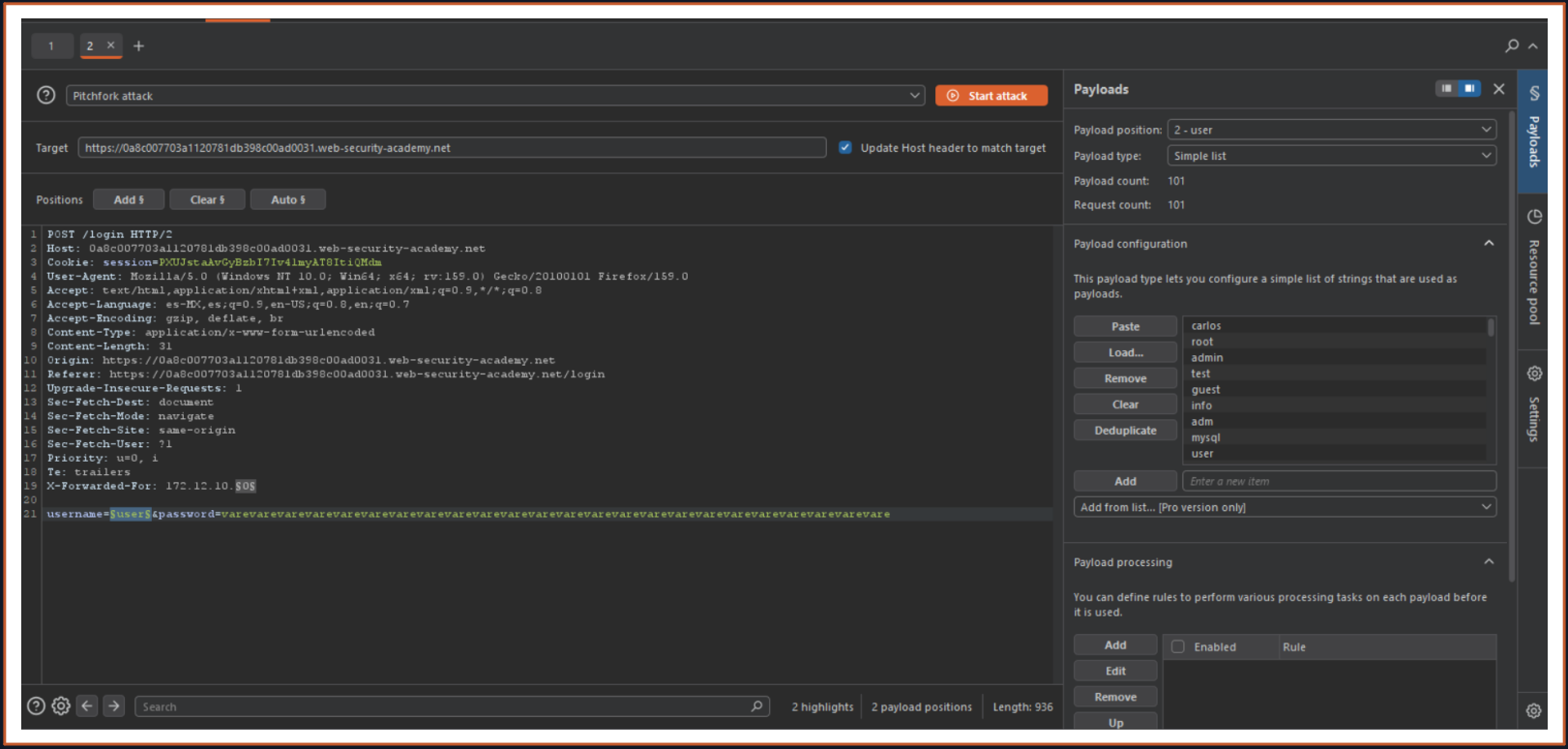
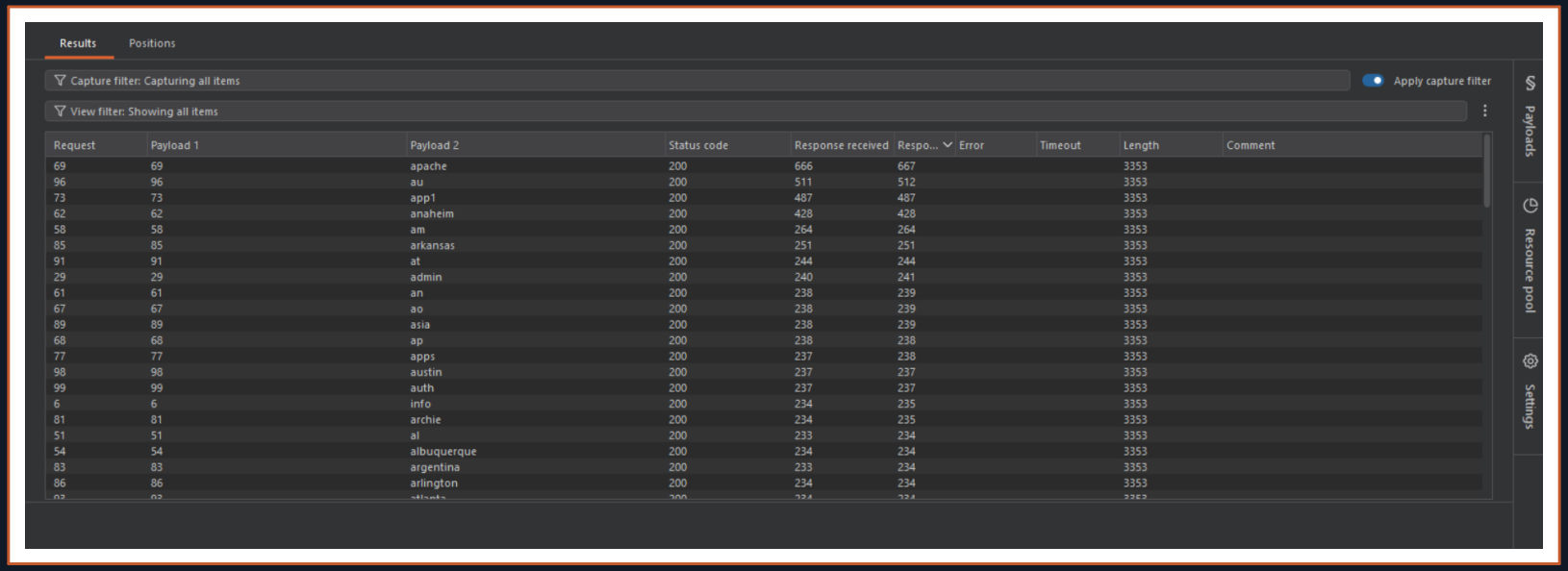


Figura 6. Lista de 101 nombres de usuario candidatos cargada en la posición «user».

6 Ordenar por tiempo de respuesta y detectar al usuario real

Al lanzar el ataque, todas las respuestas devuelven `HTTP 200` con la misma longitud (3353 bytes), por lo que ni el código de estado ni el tamaño sirven aquí. Sin embargo, al ordenar la tabla de resultados por la columna Response received (tiempo de respuesta), el payload `apache` destaca con 666 ms, muy por encima del resto (511 ms o menos): el servidor tardó más porque sí realizó el cálculo de hash de la contraseña para ese usuario.

Resultado: el nombre de usuario válido es `apache`.



Request	Payload 1	Payload 2	Status code	Response received	Respo...	Error	Timeout	Length	Comment
69	69	apache	200	666	667			3353	
96	96	au	200	511	512			3353	
73	73	app1	200	487	487			3353	
62	62	anaheim	200	428	428			3353	
58	58	am	200	264	264			3353	
85	85	arkansas	200	251	251			3353	
91	91	at	200	244	244			3353	
29	29	admin	200	240	241			3353	
61	61	an	200	238	239			3353	
67	67	ao	200	238	239			3353	
89	89	asia	200	238	239			3353	
68	68	ap	200	238	238			3353	
77	77	apps	200	237	238			3353	
98	98	austin	200	237	237			3353	
99	99	auth	200	237	237			3353	
6	6	info	200	234	235			3353	
81	81	archie	200	234	235			3353	
51	51	al	200	233	234			3353	
54	54	albuquerque	200	234	234			3353	
83	83	argentina	200	233	234			3353	
86	86	arlington	200	234	234			3353	

Figura 7. Resultados ordenados por tiempo: «apache» (666 ms) es un claro valor atípico.

7 Repetir el ataque Pitchfork sobre el campo «password»

Con el usuario confirmado, se reconfigura Intruder: el cuerpo pasa a ser `username=apache&password;=$password$`, manteniendo la rotación de `X-Forwarded-For` para seguir evadiendo el bloqueo, y se carga la lista de candidate passwords comunes (123456, password, 12345678, qwerty, 123456789, 12345, 1234, 111111, 1234567…).

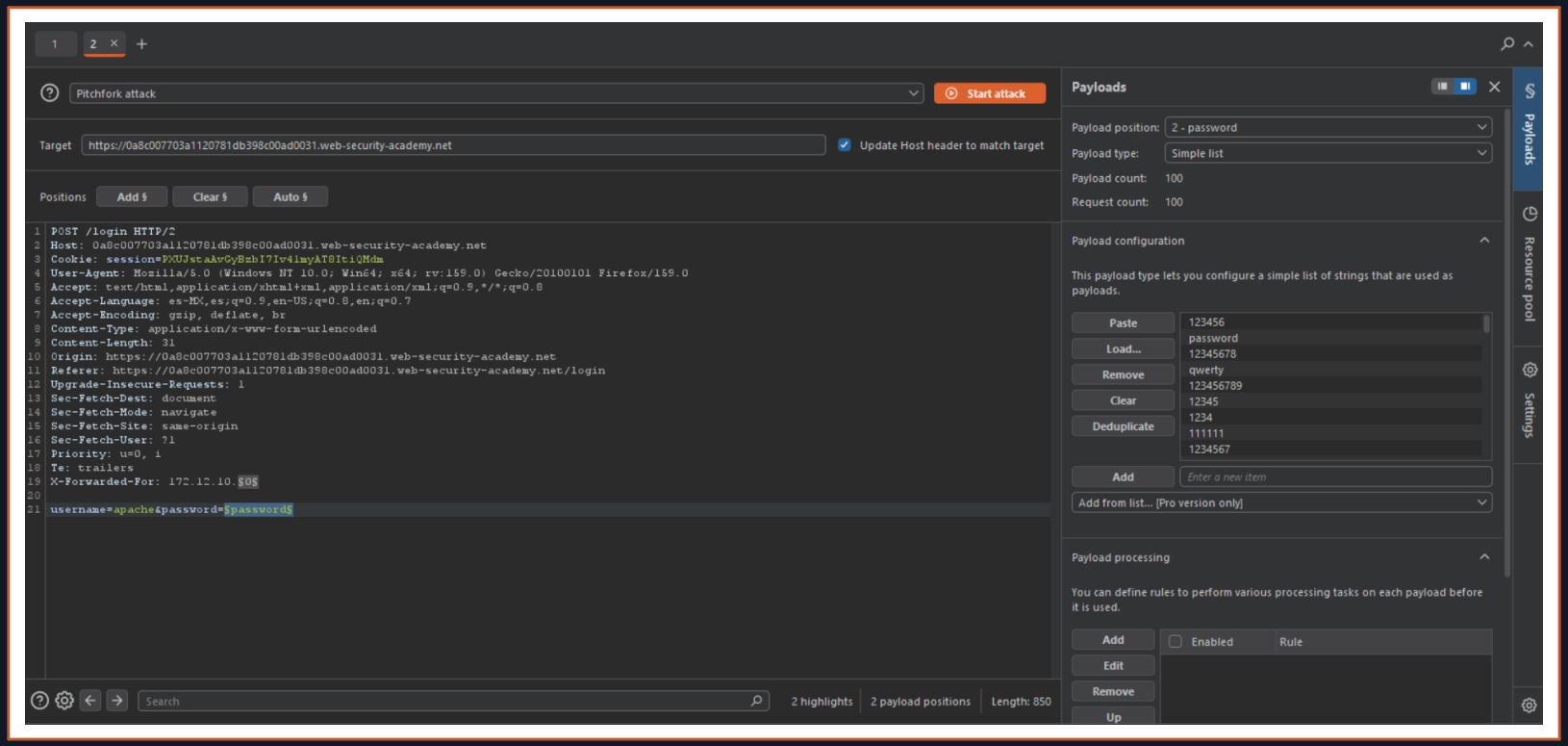
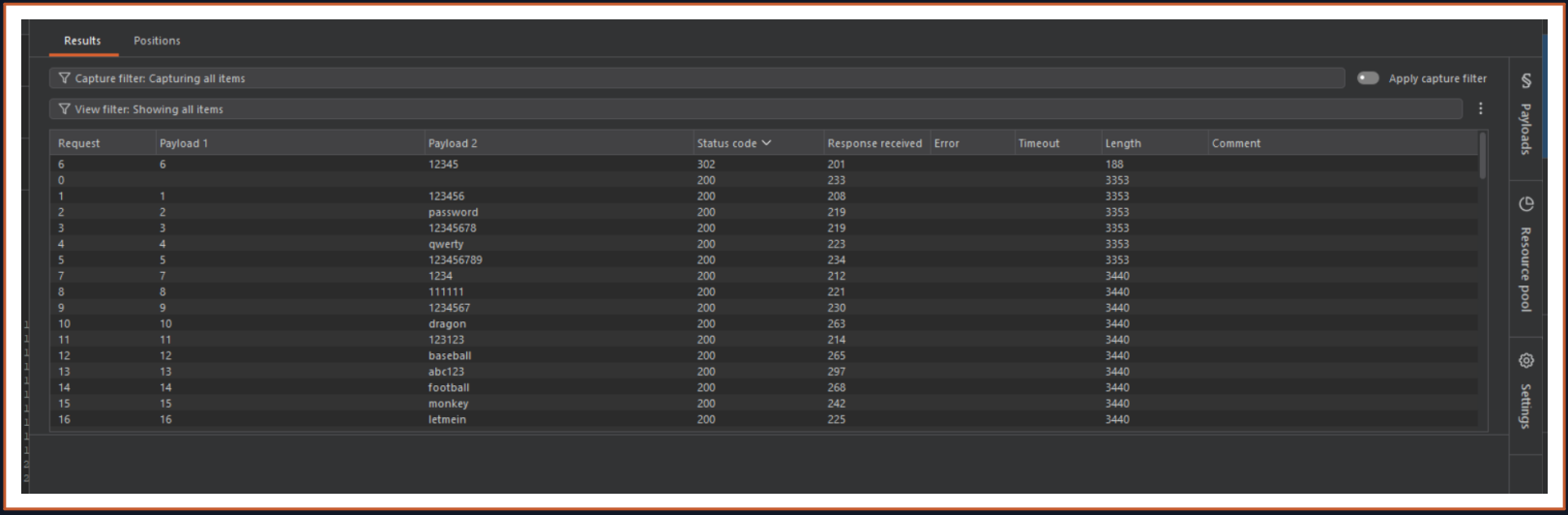


Figura 8. Usuario fijo «apache», payload sobre «password» con contraseñas candidatas.

8 Ordenar por código de estado y detectar el login correcto

Al ordenar los resultados por Status code, una única fila destaca con `HTTP 302 Found` (en lugar del `200` habitual de las contraseñas incorrectas), con una respuesta mucho más corta (188 bytes) y un tiempo de solo 201 ms: el payload `12345` es la contraseña correcta.

Resultado: la contraseña correcta es `12345`.



Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
6	6	12345	302	201			188	
0			200	233			3353	
1	1	123456	200	208			3353	
2	2	password	200	219			3353	
3	3	12345678	200	219			3353	
4	4	qwerty	200	223			3353	
5	5	123456789	200	234			3353	
7	7	1234	200	212			3440	
8	8	111111	200	221			3440	
9	9	1234567	200	230			3440	
10	10	dragon	200	263			3440	
11	11	123123	200	214			3440	
12	12	baseball	200	265			3440	
13	13	abc123	200	297			3440	
14	14	football	200	268			3440	
15	15	monkey	200	242			3440	
16	16	letmein	200	225			3440	

Figura 9. El payload «12345» devuelve 302 Found: contraseña correcta hallada.

9 Introducir las credenciales manualmente en el formulario

Con `apache / 12345` ya identificadas, se vuelve al formulario de login real para iniciar sesión. En un primer intento, un error al escribir la contraseña provoca la respuesta «Invalid username or password.», recordando que, a diferencia del ataque automatizado, aquí ya no hay una IP falsificada que oculte los intentos fallidos frente al bloqueo.

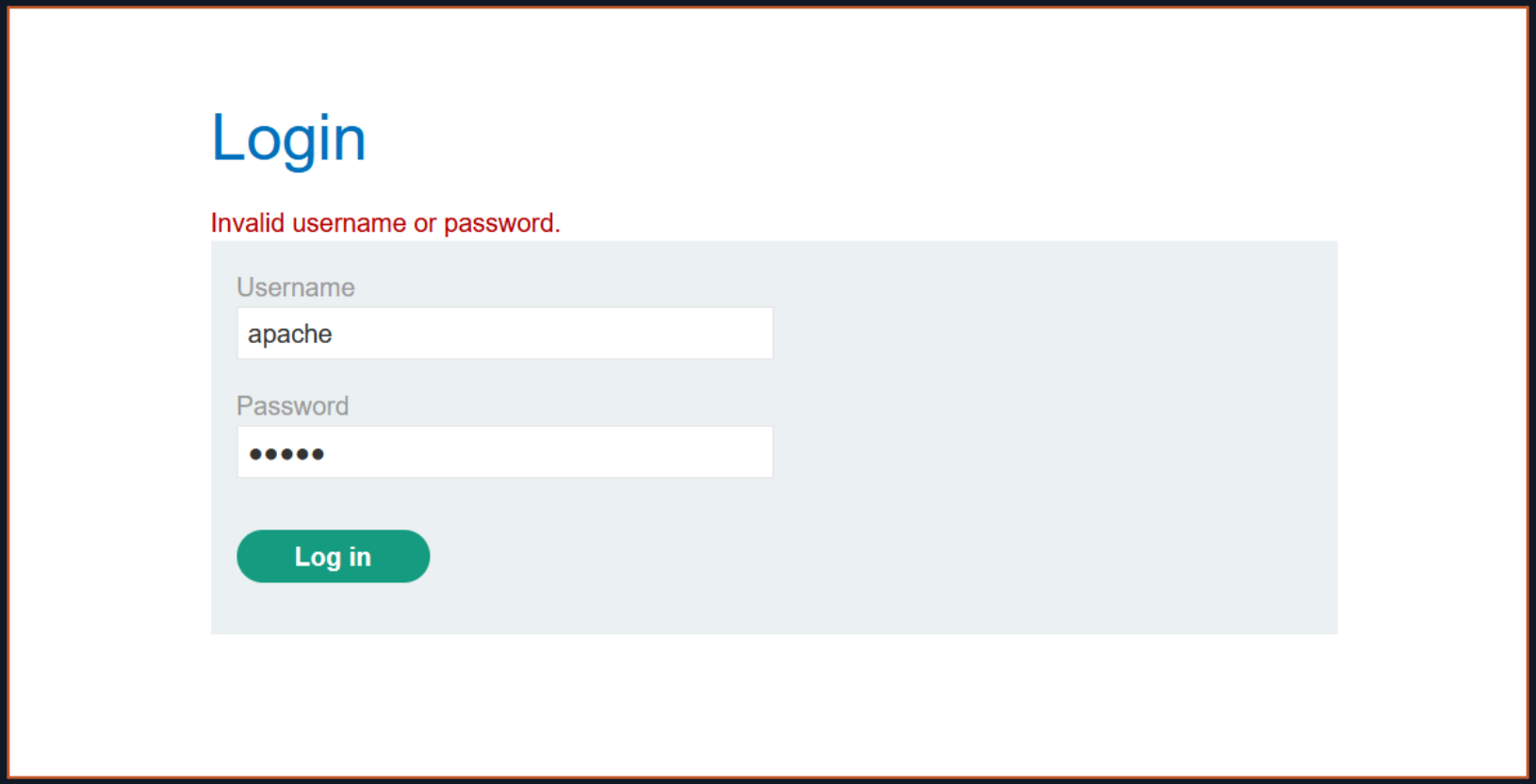


Figura 10. Primer intento manual con un error de escritura → «Invalid username or password».

10 Confirmar el acceso y la resolución del laboratorio

Al corregir el error e introducir correctamente `apache / 12345`, la aplicación concede acceso y muestra la página «My Account» del usuario, con su correo real (`apache@normal-user.net`). El laboratorio cambia su estado a «Solved».

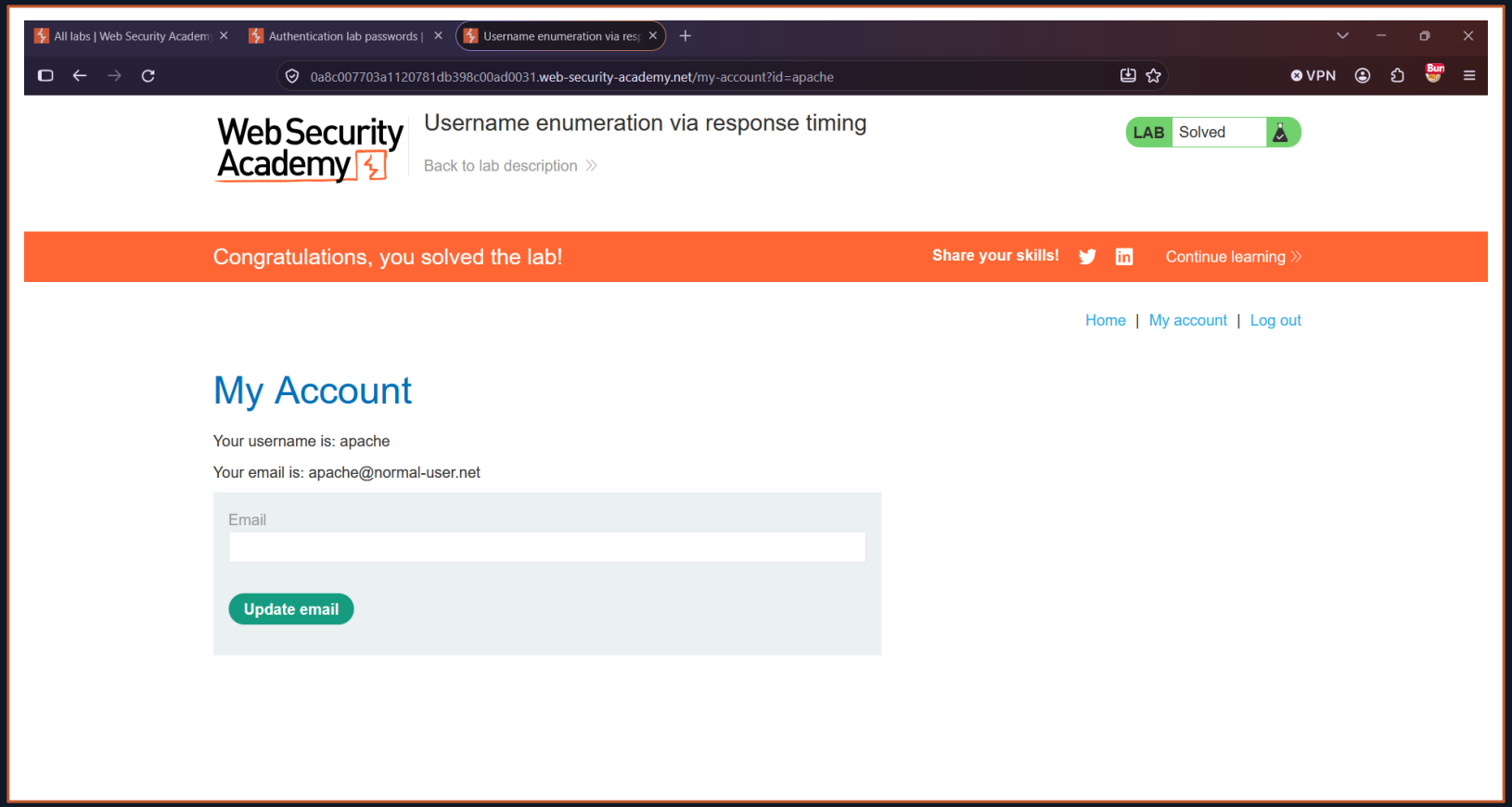


Figura 11. Acceso concedido a la cuenta de «apache» — laboratorio resuelto.

Resumen del flujo de ataque

Paso	Acción	Resultado
1	Pitchfork: IP rotada + fuerza bruta de username	Usuario válido por tiempo de respuesta: apache
2	Pitchfork: IP rotada + fuerza bruta de password	Contraseña válida por código 302: 12345
3	Login manual con «apache» / «12345»	Acceso concedido — Lab resuelto

03 ¿Por qué ocurrió esta vulnerabilidad?

Aquí conviven dos fallos de seguridad que se refuerzan entre sí. El primero es un canal lateral de tiempo (timing side channel): cuando el nombre de usuario existe, el servidor necesita calcular el hash de la contraseña recibida para compararlo con el almacenado (una operación deliberadamente costosa, como bcrypt o similar); cuando el usuario no existe, el servidor puede rechazar la petición de inmediato, sin ese cálculo. Esa asimetría en el trabajo realizado se traduce en una diferencia medible de milisegundos entre ambos casos, aunque el mensaje de error mostrado sea idéntico.

El segundo fallo es la protección anti fuerza bruta mal implementada: el bloqueo por demasiados intentos se basa en la cabecera `X-Forwarded-For`, un valor que el cliente controla por completo y que normalmente solo debería usarse detrás de proxies de confianza. Al no validarse su origen, basta con enviar un valor distinto en cada petición para que el servidor crea que cada intento viene de una IP diferente.

La combinación de ambos fallos es lo que hace práctico el ataque: sin la posibilidad de rotar la IP, el bloqueo tras pocos intentos impediría probar 101 usuarios y 100 contraseñas en poco tiempo; sin el canal lateral de tiempo, no habría forma de distinguir usuarios válidos sin mensajes de error diferenciados. Juntos, permiten automatizar con Burp Intruder tanto la enumeración de usuarios como la fuerza bruta de contraseñas a gran escala, sin activar ninguna defensa.

Recomendaciones de mitigación

- Realizar siempre el cálculo de hash de la contraseña (incluso con un valor ficticio) también cuando el usuario no existe, para igualar los tiempos.
- No confiar en `X-Forwarded-For` salvo detrás de un proxy de confianza que sobrescriba ese valor; usar la IP real de la conexión.
- Aplicar bloqueo por cuenta (ligado al usuario), no solo por IP, para que rotar la IP no elimine la protección.
- Añadir CAPTCHA o retardo progresivo tras varios intentos fallidos, independientemente del origen.
- Monitorizar patrones de tráfico distribuido anómalo hacia el endpoint de login.

Documento elaborado por vareCruzz como ejercicio de aprendizaje en seguridad web ofensiva, basado en el laboratorio «Username enumeration via response timing» de PortSwigger Web Security Academy.